Lab-5 | Static Code Analysis

Name: Chaithanya B
SRN: PES1UG24CS123
Section: B

Project: Hostel Room Allocation System

Git repository: https://github.com/Chaithanya-Bainkrodu/SE-Labs-PES1UG24CS123/tree/main/Lab5

1. Introduction

Static code analysis examines source code without executing the application. It helps identify likely bugs, unsafe coding patterns, maintainability problems, and style violations. It complements runtime checks and testing; clean reports do not prove that a program is correct or fully secure.

Tool	Purpose
Pylint	Checks code quality, naming, documentation, unused code, and potentially faulty patterns.
Bandit	Checks Python code for common security-sensitive patterns, such as unsafe YAML loading and debug mode.
Flake8	Checks PEP 8 style and selected programming errors, including spacing, long lines, and unused imports.

Recorded results

Tool	Before fixing	After fixing
Pylint	5.84/10	10.00/10
Bandit	5 findings: 1 high, 2 medium, 2 low	No issues identified
Flake8	Spacing, line-length, unused-import and type-check findings	Saved report is empty (0 bytes)

Evidence and submission notes

All six report files are included in full later in this PDF. All screenshot evidence consists of the supplied VS Code screenshots, included without recolouring. Full saved report contents are also included. The empty final Flake8 file is explicitly identified rather than filled with invented output.

Section 6 contains sample reflection questions and answers based on the hostel-allocation project.

Separate fix commits verified in the repository: f75f5cd (Flake8) · 2b0efaa (Pylint) · 4507ac8 (Bandit).

2. Issue identification table (1/2)

Line numbers refer to the original file. Logic-only issues were identified by reviewing the code and its behaviour; they are not all direct tool findings.

Issue	Type	Line(s)	Description	Fix approach
B201: Flask debug mode	Security — High	80	Debug mode exposes the interactive debugger if reachable.	Set debug=False.
B506: Unsafe YAML loading	Security — Medium	21	The loader can construct arbitrary Python objects.	Use yaml.safe_load().
B612: Remote logging configuration	Security — Medium	72	Remote configuration introduces an unnecessary code-execution risk.	Replace the listener with local logging configuration.
B106: Hardcoded password	Security — Low	66	A password is stored directly in source code.	Read it from an environment variable and reject missing values.
B311: Predictable lottery randomness	Security — Low	56	Standard pseudo-random sampling is unsuitable when unpredictability matters.	Use secrets.SystemRandom().sample().
W0102: Mutable default argument	Code quality	29	A default list is shared across calls and can cause bugs if modified.	Use None and initialize a list inside the function.
C0123: Type checking	Code quality	30	Direct type comparison is unidiomatic.	Use isinstance() and reject boolean year values.
W0613: Unused gender argument	Logic / code quality	29–38	Allocation ignores room gender compatibility.	Check room gender before allocating.

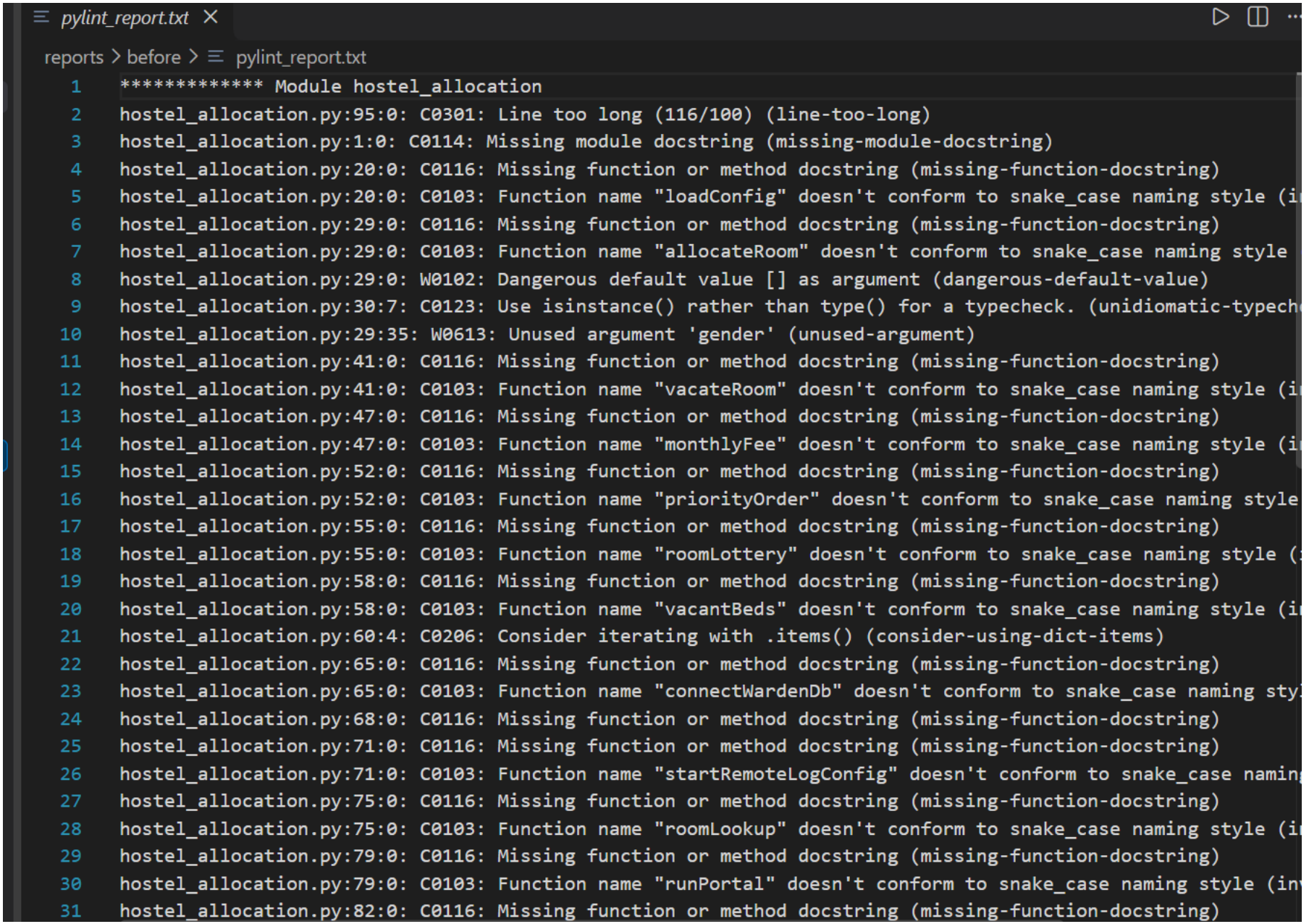
2. Issue identification table (2/2)

Line numbers refer to the original file. Logic-only issues were identified by reviewing the code and its behaviour; they are not all direct tool findings.

Issue	Type	Line(s)	Description	Fix approach
Room capacity check	Logic	34	A full room is not skipped because the check uses >.	Use >= to prevent over-allocation.
Duplicate allocation	Logic	29–39	Repeated allocation can add the same student more than once.	Return the existing allocation before assigning a bed.
Incomplete vacation	Logic	41–45	Deleting an allocation does not remove the room occupant.	Remove both the allocation and the occupant entry.
Incorrect seniority ordering	Logic	52–53	Ascending year order puts juniors first.	Sort by year with reverse=True.
C0206: Dictionary iteration and vacant beds	Code quality / logic	58–63	Partially occupied rooms are excluded from the vacant-bed count.	Iterate over room values and sum capacity minus occupancy.
C0103 / C0114 / C0116: Naming and documentation	Maintainability	Throughout	Function names and documentation do not follow conventions.	Use snake_case and add module and function docstrings.
W0611 / C0301: Unused import and long line	Code quality	2, 95	An unused import and an overly long expression reduce clarity.	Remove sys and split the expression into readable steps.
E302 / E305: Top-level spacing	Style	Various	Top-level functions and the final statement have insufficient blank-line separation.	Add two blank lines between top-level definitions and after the final function.
E501: Long lines	Style	25, 66, 95	Some lines exceed Flake8's default 79-character limit.	Split dictionaries, calls, and expressions across shorter lines.

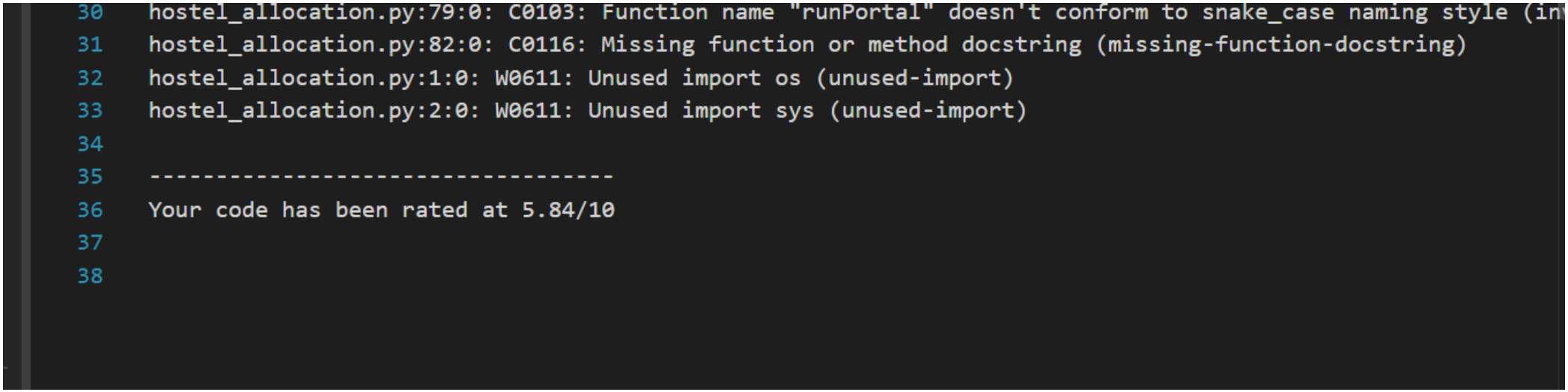
3. Before fixing — Pylint (1/2)

Original supplied VS Code screenshot. Complete report text is included in Section 5.



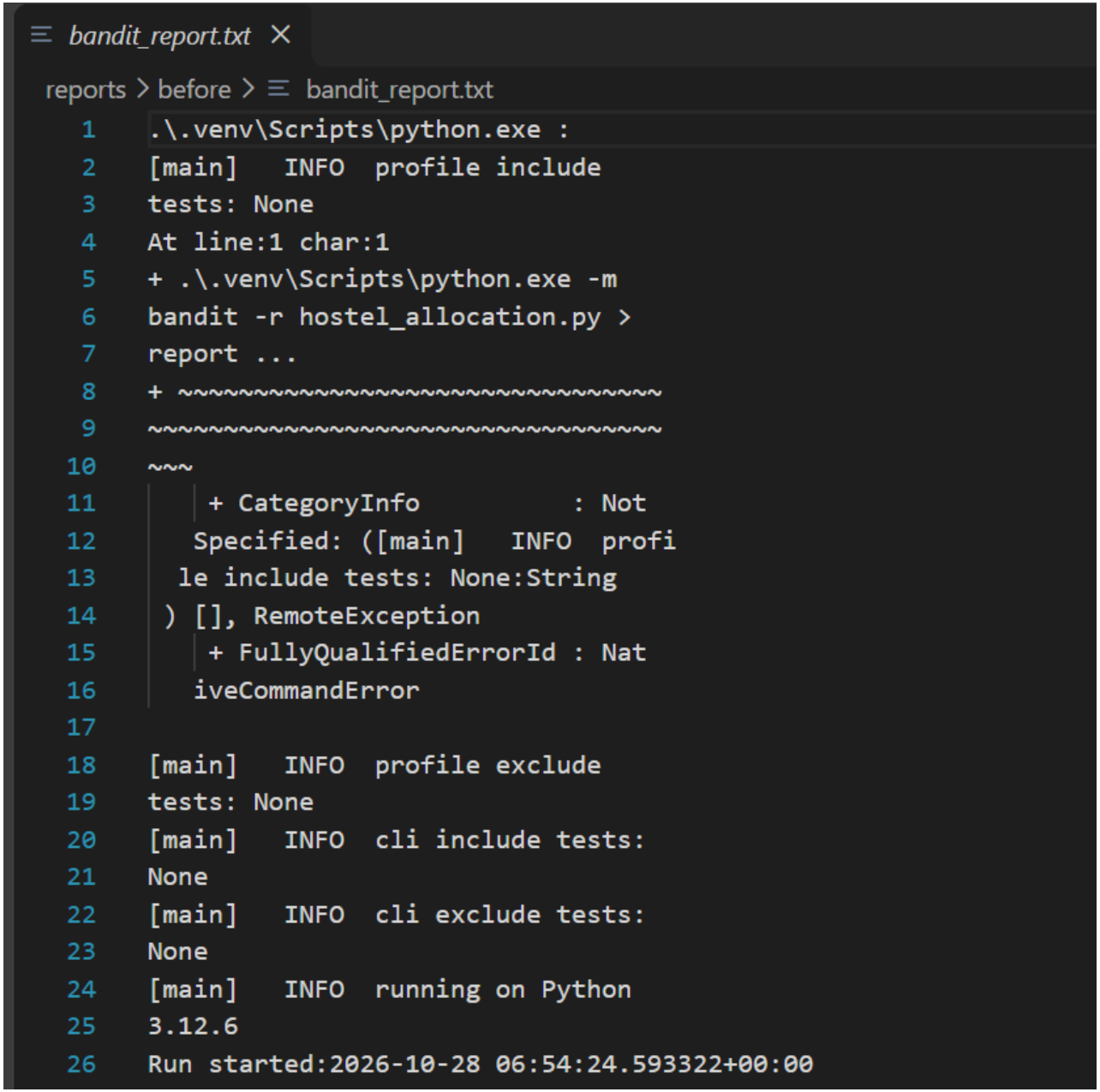
3. Before fixing — Pylint (2/2)

Original supplied VS Code screenshot. Complete report text is included in Section 5.



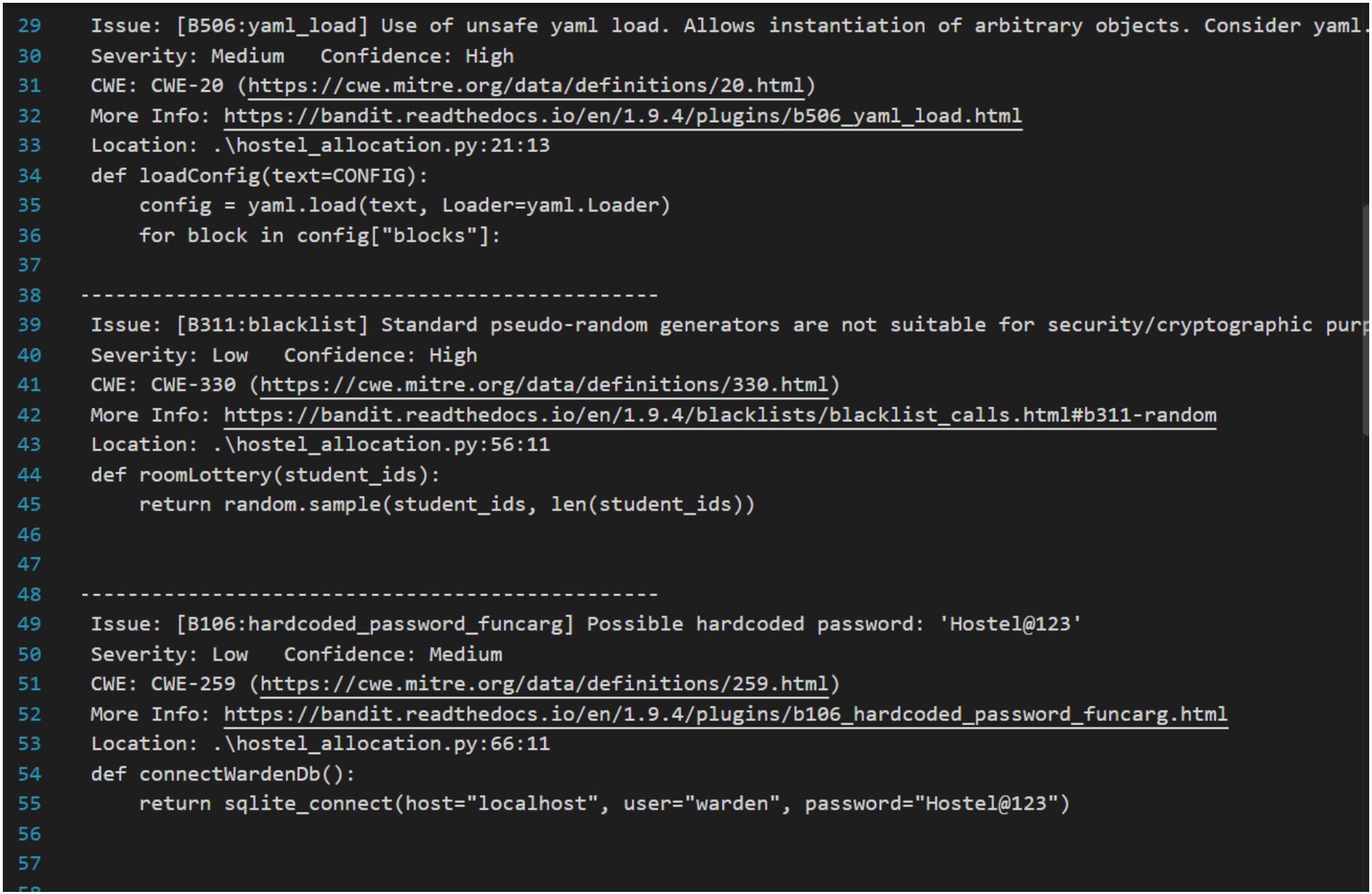
3. Before fixing — Bandit (1/4)

Original supplied VS Code screenshot. Complete report text is included in Section 5.



3. Before fixing — Bandit (2/4)

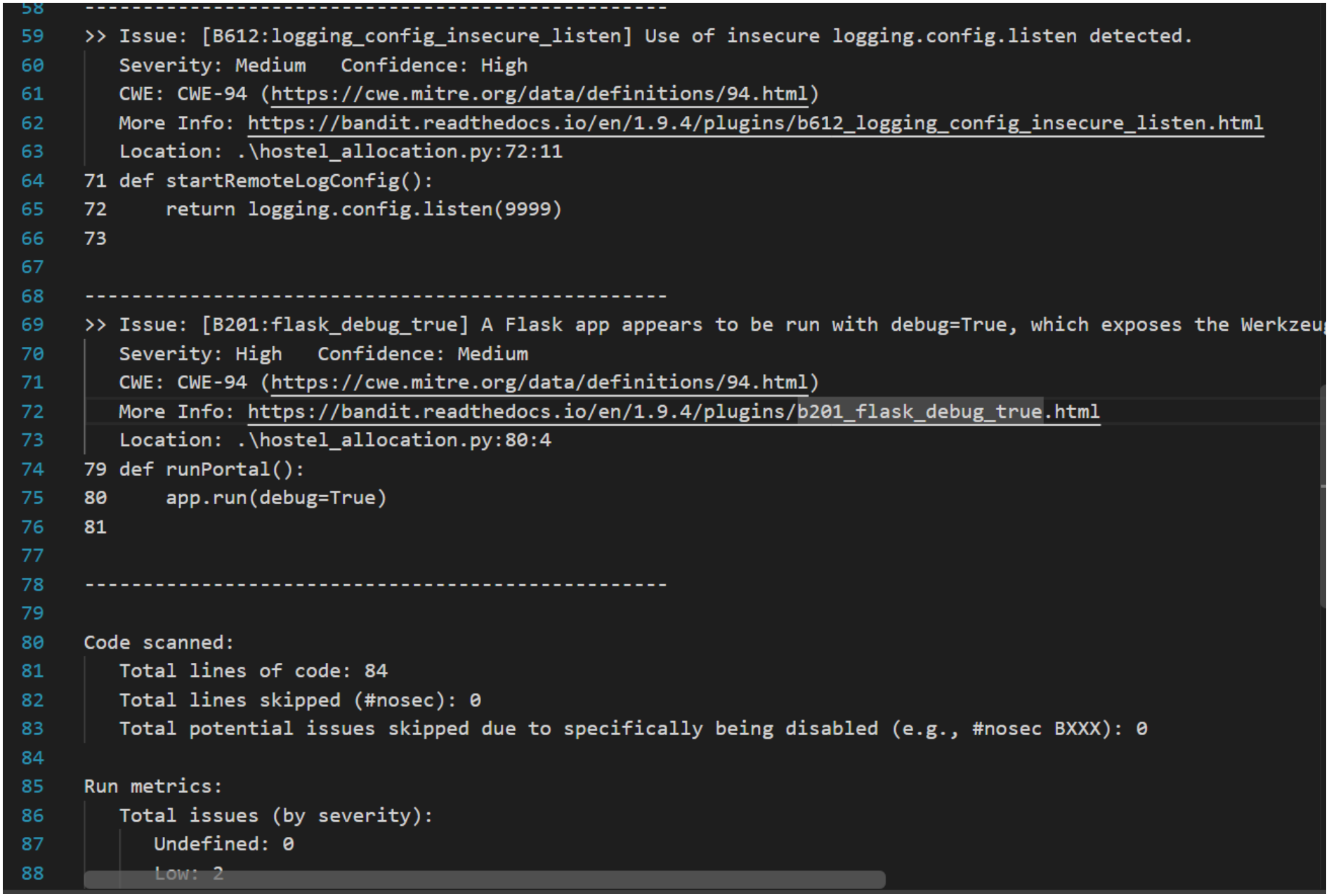
Original supplied VS Code screenshot. Complete report text is included in Section 5.



```
29    Issue: [B506:yaml_load] Use of unsafe yaml load. Allows instantiation of arbitrary objects. Consider yaml.
30    Severity: Medium   Confidence: High
31    CWE: CWE-20 (https://cwe.mitre.org/data/definitions/20.html)
32    More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b506_yaml_load.html
33    Location: .\hostel_allocation.py:21:13
34    def loadConfig(text=CONFIG):
35        config = yaml.load(text, Loader=yaml.Loader)
36        for block in config["blocks"]:
37
38    --------------------------------------------------
39    Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purp
40    Severity: Low   Confidence: High
41    CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
42    More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
43    Location: .\hostel_allocation.py:56:11
44    def roomLottery(student_ids):
45        return random.sample(student_ids, len(student_ids))
46
47
48    --------------------------------------------------
49    Issue: [B106:hardcoded_password_funcarg] Possible hardcoded password: 'Hostel@123'
50    Severity: Low   Confidence: Medium
51    CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
52    More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b106_hardcoded_password_funcarg.html
53    Location: .\hostel_allocation.py:66:11
54    def connectWardenDb():
55        return sqlite_connect(host="localhost", user="warden", password="Hostel@123")
56
57
```

3. Before fixing — Bandit (3/4)

Original supplied VS Code screenshot. Complete report text is included in Section 5.



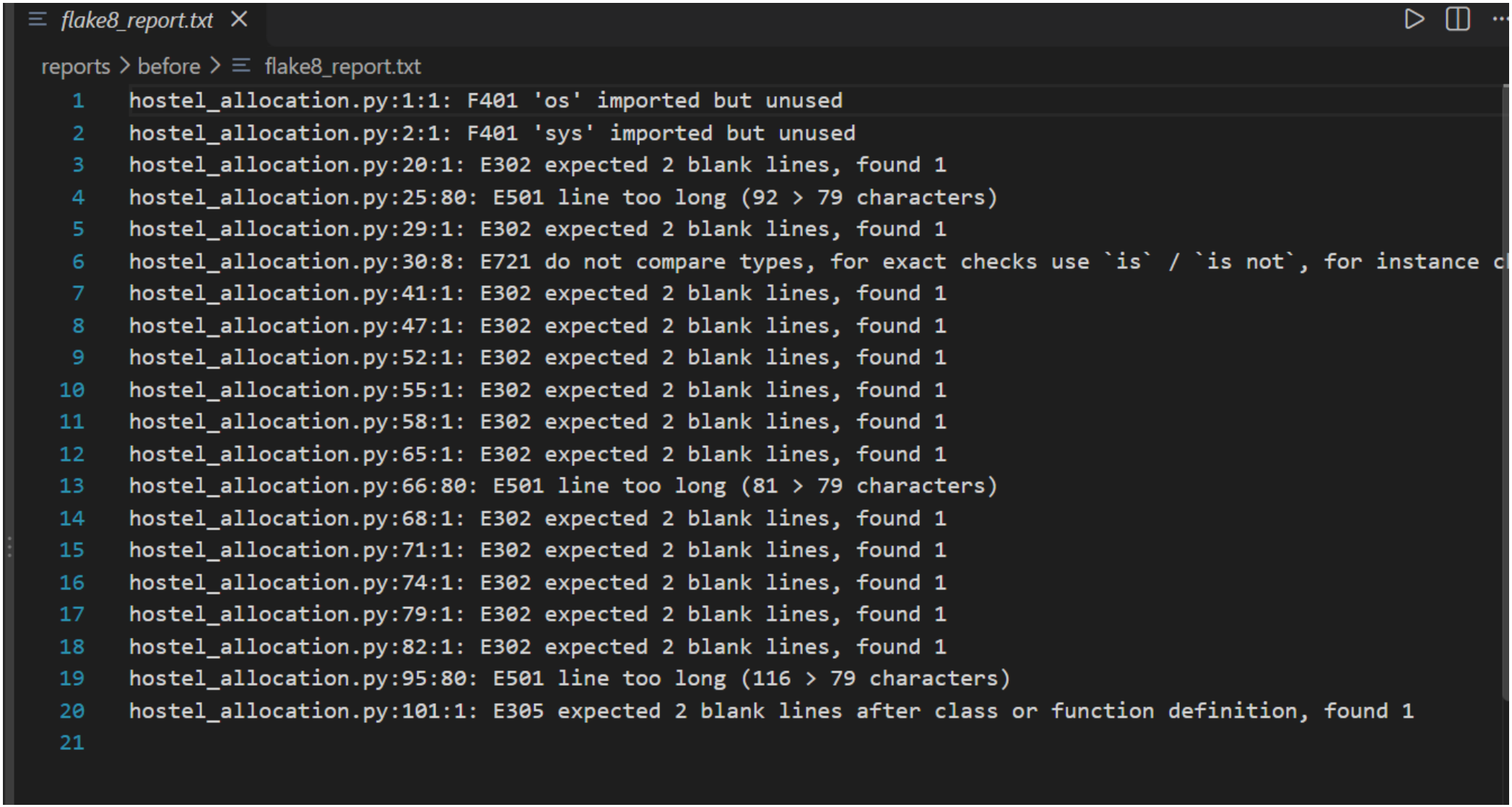
3. Before fixing — Bandit (4/4)

Original supplied VS Code screenshot. Complete report text is included in Section 5.

```
78  --------------------------------------------------
79
80  Code scanned:
81      Total lines of code: 84
82      Total lines skipped (#nosec): 0
83      Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0
84
85  Run metrics:
86      Total issues (by severity):
87          Undefined: 0
88          Low: 2
89          Medium: 2
90          High: 1
91      Total issues (by confidence):
92          Undefined: 0
93          Low: 0
94          Medium: 2
95          High: 3
96  Files skipped (0):
97
```

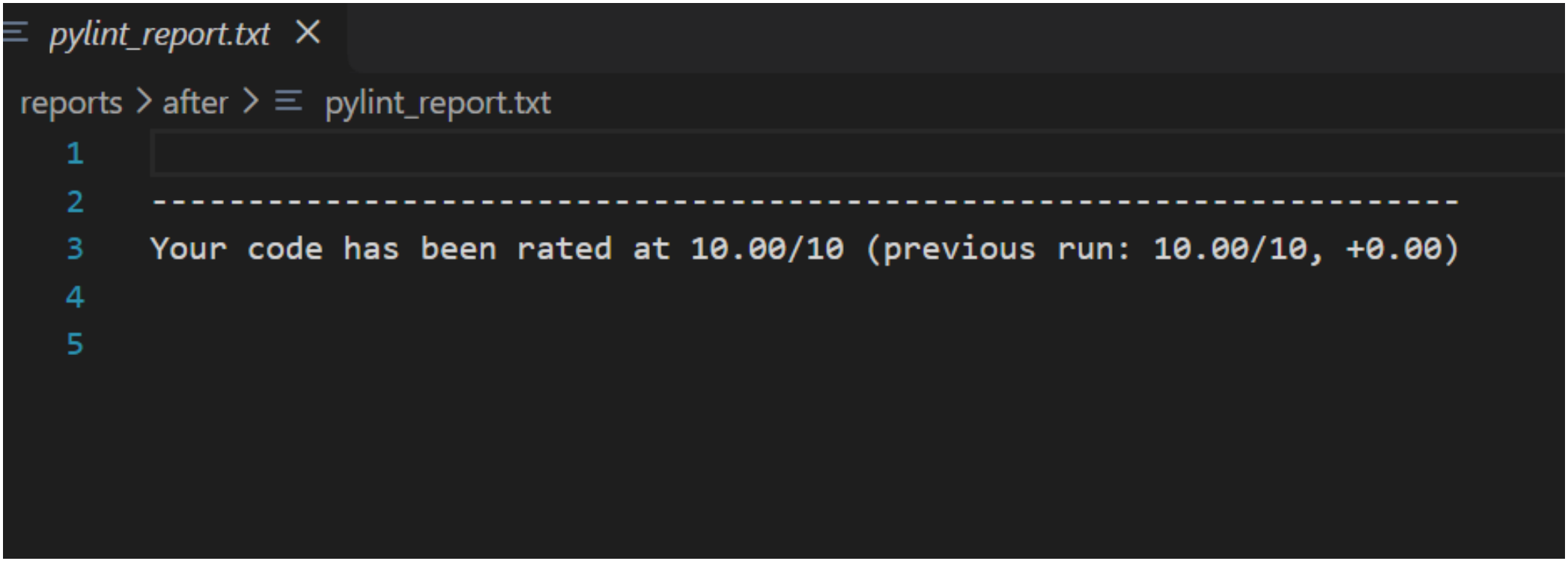
3. Before fixing — Flake8

Original supplied VS Code screenshot. Complete report text is included in Section 5.



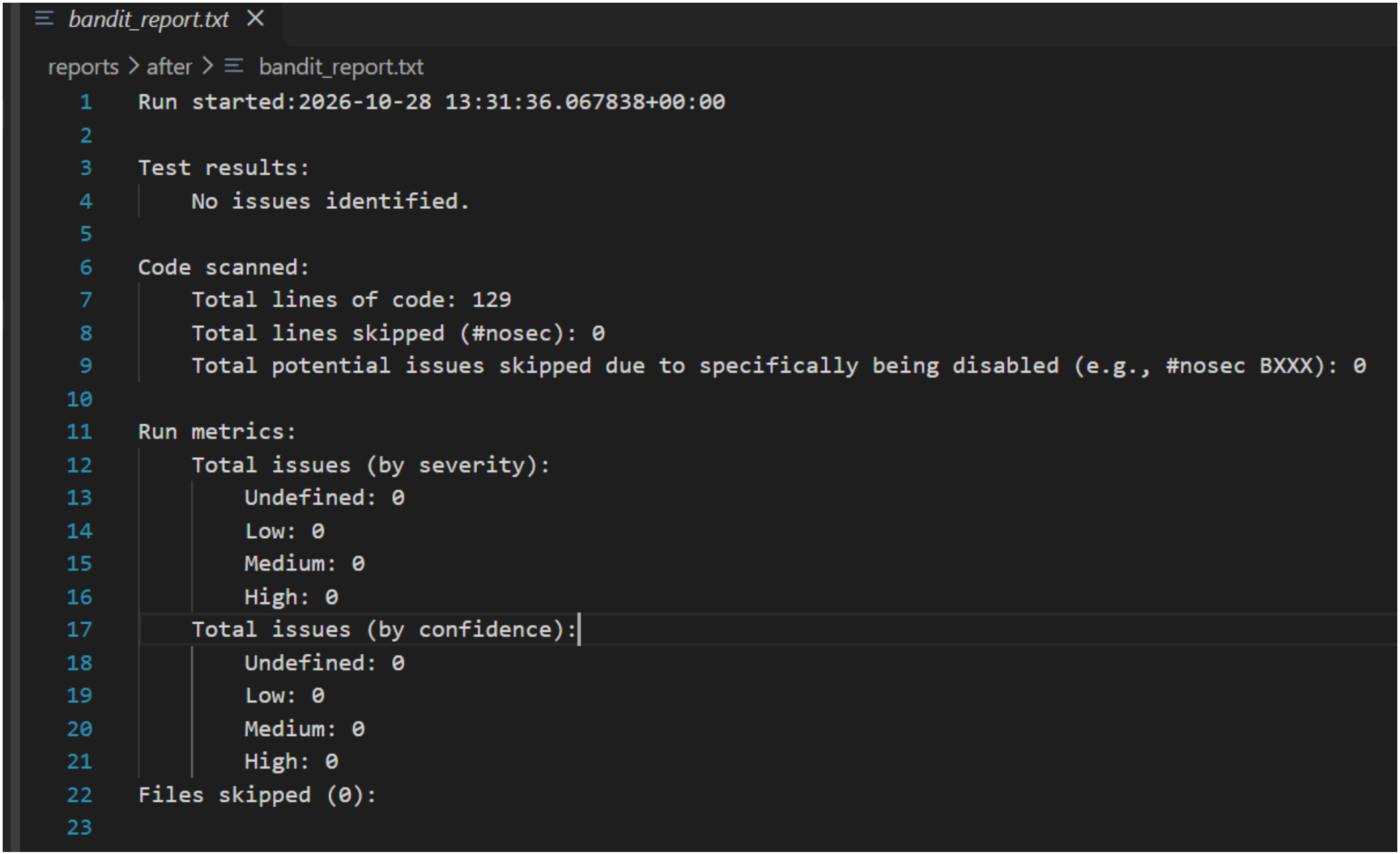
4. After fixing — Pylint

Original supplied VS Code screenshot. Complete report text is included in Section 5.



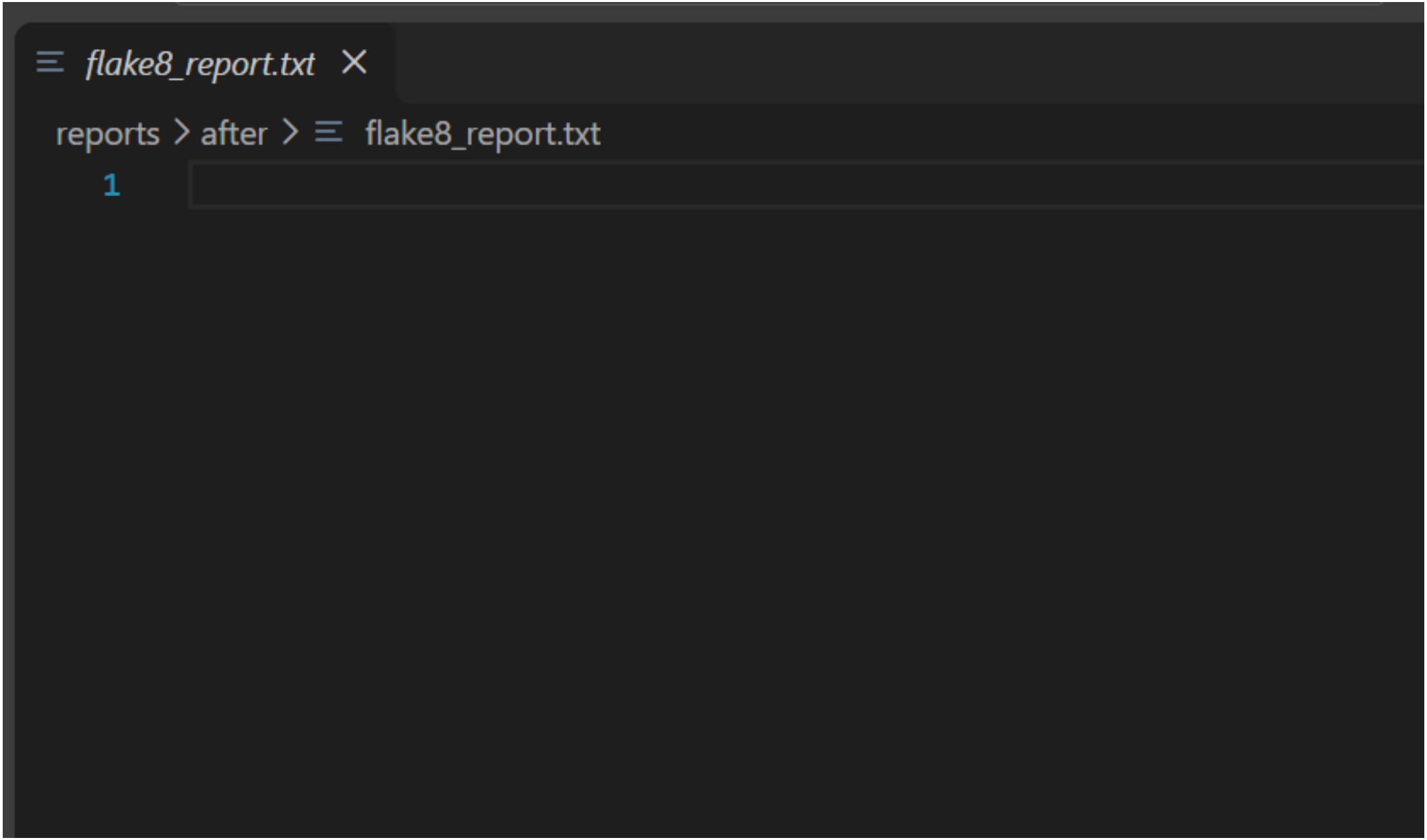
4. After fixing — Bandit

Original supplied VS Code screenshot. Complete report text is included in Section 5.



4. After fixing — Flake8

Original supplied VS Code screenshot. Complete report text is included in Section 5.



5.1 Pylint — Before

reports/before/pylint_report.txt · Part 1 of 2

```
************* Module hostel_allocation
hostel_allocation.py:95:0: C0301: Line too long (116/100) (line-too-long)
hostel_allocation.py:1:0: C0114: Missing module docstring (missing-module-docstring)
hostel_allocation.py:20:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:20:0: C0103: Function name "loadConfig" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:29:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:29:0: C0103: Function name "allocateRoom" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:29:0: W0102: Dangerous default value [] as argument
(dangerous-default-value)
hostel_allocation.py:30:7: C0123: Use isinstance() rather than type() for a typecheck.
(unidiomatic-typecheck)
hostel_allocation.py:29:35: W0613: Unused argument 'gender' (unused-argument)
hostel_allocation.py:41:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:41:0: C0103: Function name "vacateRoom" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:47:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:47:0: C0103: Function name "monthlyFee" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:52:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:52:0: C0103: Function name "priorityOrder" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:55:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:55:0: C0103: Function name "roomLottery" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:58:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:58:0: C0103: Function name "vacantBeds" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:60:4: C0206: Consider iterating with .items() (consider-using-dict-items)
hostel_allocation.py:65:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:65:0: C0103: Function name "connectWardenDb" doesn't conform to
snake_case naming style (invalid-name)
hostel_allocation.py:68:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:71:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:71:0: C0103: Function name "startRemoteLogConfig" doesn't conform to
snake_case naming style (invalid-name)
hostel_allocation.py:75:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:75:0: C0103: Function name "roomLookup" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:79:0: C0116: Missing function or method docstring
(missing-function-docstring)
```

5.1 Pylint — Before

reports/before/pylint_report.txt · Part 2 of 2

```
hostel_allocation.py:79:0: C0103: Function name "runPortal" doesn't conform to snake_case
naming style (invalid-name)
hostel_allocation.py:82:0: C0116: Missing function or method docstring
(missing-function-docstring)
hostel_allocation.py:1:0: W0611: Unused import os (unused-import)
hostel_allocation.py:2:0: W0611: Unused import sys (unused-import)

-----------------------------------
Your code has been rated at 5.84/10
```

5.2 Bandit — Before

reports/before/bandit_report.txt · Part 1 of 2

The PowerShell diagnostic wrapper at the beginning is part of the saved file. Bandit completed the scan; its findings and metrics follow.

```
.\.venv\Scripts\python.exe :
[main]  INFO    profile include
tests: None
At line:1 char:1
+ .\.venv\Scripts\python.exe -m
bandit -r hostel_allocation.py >
report ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
~~~
    + CategoryInfo          : Not
   Specified: ([main]   INFO    profi
  le include tests: None:String
 ) [], RemoteException
    + FullyQualifiedErrorId : Nat
   iveCommandError

[main]  INFO    profile exclude
tests: None
[main]  INFO    cli include tests:
None
[main]  INFO    cli exclude tests:
None
[main]  INFO    running on Python
3.12.6
Run started:2026-10-28 06:54:24.593322+00:00

Test results:
>> Issue: [B506:yaml_load] Use of unsafe yaml load. Allows instantiation of arbitrary objects.
 Consider yaml.safe_load().
   Severity: Medium   Confidence: High
   CWE: CWE-20 (https://cwe.mitre.org/data/definitions/20.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b506_yaml_load.html
   Location: .\hostel_allocation.py:21:13
20  def loadConfig(text=CONFIG):
21      config = yaml.load(text, Loader=yaml.Loader)
22      for block in config["blocks"]:

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for
security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\hostel_allocation.py:56:11
55  def roomLottery(student_ids):
56      return random.sample(student_ids, len(student_ids))
57

--------------------------------------------------
>> Issue: [B106:hardcoded_password_funcarg] Possible hardcoded password: 'Hostel@123'
   Severity: Low   Confidence: Medium
```

5.2 Bandit — Before

reports/before/bandit_report.txt · Part 2 of 2

```
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b106_hardcoded_password_funcarg.html
   Location: .\hostel_allocation.py:66:11
65  def connectWardenDb():
66      return sqlite_connect(host="localhost", user="warden", password="Hostel@123")
67

--------------------------------------------------
>> Issue: [B612:logging_config_insecure_listen] Use of insecure logging.config.listen
detected.
   Severity: Medium   Confidence: High
   CWE: CWE-94 (https://cwe.mitre.org/data/definitions/94.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b612_logging_config_insecure_listen.html
   Location: .\hostel_allocation.py:72:11
71  def startRemoteLogConfig():
72      return logging.config.listen(9999)
73

--------------------------------------------------
>> Issue: [B201:flask_debug_true] A Flask app appears to be run with debug=True, which exposes
 the Werkzeug debugger and allows the execution of arbitrary code.
   Severity: High   Confidence: Medium
   CWE: CWE-94 (https://cwe.mitre.org/data/definitions/94.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b201_flask_debug_true.html
   Location: .\hostel_allocation.py:80:4
79  def runPortal():
80      app.run(debug=True)
81

--------------------------------------------------

Code scanned:
    Total lines of code: 84
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 2
        Medium: 2
        High: 1
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 2
        High: 3
Files skipped (0):
```

5.3 Flake8 — Before

reports/before/flake8_report.txt

```
hostel_allocation.py:1:1: F401 'os' imported but unused
hostel_allocation.py:2:1: F401 'sys' imported but unused
hostel_allocation.py:20:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:25:80: E501 line too long (92 > 79 characters)
hostel_allocation.py:29:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:30:8: E721 do not compare types, for exact checks use `is` / `is not`,
for instance checks use `isinstance()`
hostel_allocation.py:41:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:47:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:52:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:55:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:58:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:65:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:66:80: E501 line too long (81 > 79 characters)
hostel_allocation.py:68:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:71:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:74:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:79:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:82:1: E302 expected 2 blank lines, found 1
hostel_allocation.py:95:80: E501 line too long (116 > 79 characters)
hostel_allocation.py:101:1: E305 expected 2 blank lines after class or function definition,
found 1
```

5.4 Pylint — After

reports/after/pylint_report.txt

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

5.5 Bandit — After

reports/after/bandit_report.txt

```
Run started:2026-10-28 13:31:36.067838+00:00

Test results:
    No issues identified.

Code scanned:
    Total lines of code: 129
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
```

5.6 Flake8 — After

reports/after/flake8_report.txt

This file contains no text (0 bytes). The complete file content is therefore empty. This explanatory note is not tool output.

6. Reflection

Sample reflection questions

1. Which issue would I prioritise, and why?

I would prioritise Flask debug mode because Bandit classified it as a high-severity finding. If the development debugger is exposed, it can create a serious code-execution risk. Setting `debug=False` removes that specific unsafe setting. I would then address unsafe YAML loading and the remote logging configuration listener, both reported as medium severity. This exercise showed me why findings should be prioritised by their potential impact rather than fixed only in the order they appear. Style improvements are useful, but they should not distract from security-sensitive behaviour.

2. What did reviewing the allocation logic reveal that the tool reports alone could not establish?

The hostel rules required more than clean formatting or a high quality score. A room at capacity must not receive another occupant, the selected room must match the student's gender, and requesting an allocation twice must not consume two beds. Vacating must also update both the allocation record and the occupant list. I addressed these cases through a capacity check using >=, a compatibility check, an early return for existing allocations and removal of the occupant when vacating. The unused gender argument was a useful warning, but understanding its effect required reviewing the intended allocation rules.

3. How would I check that the fixes preserve the intended behaviour?

I would use small, repeatable tests with a known room configuration. For capacity, I would fill a room and verify that the next request does not increase its occupancy. For duplicate requests, I would allocate the same student twice and check that only one bed is occupied. I would verify that a student receives a compatible room, that vacating increases the vacant-bed count by one, and that higher-year students appear first in priority ordering. I would also check that boolean and non-integer year values are rejected. These are proposed verification steps; automated regression-test results are not included in this report.

4. What do the final tool results tell me about the quality of the program?

The recorded results show that the documented changes resolved the reported findings under the scan settings used. Pylint improved from 5.84/10 to 10.00/10, Bandit went from five findings to no issues identified, and the final Flake8 report contains no diagnostic text. These results are useful evidence of improved code quality, but they are not a certificate of complete correctness or security. For example, the monthly-fee function still needs its completed-30-day-period rule checked against the actual billing requirements. I would combine static analysis with runtime tests and manual review before relying on the system in practice.